

# Güvenlik Gereksinimleri

CEN429 Güvenli Programlama — Hafta 13

Dr. Öğr. Üyesi Uğur CORUH · 11.12.2026

## Bugünün planı (3 saat)

---

| Saat | Bölüm | Konu                                                                                 |
|------|-------|--------------------------------------------------------------------------------------|
| 1    | 0–3   | Temel kavramlar · iyi gereksinim · izlenebilirlik · gereksinim bloğu · devredilenler |
| 2    | 4–5   | Ortak Kriterler (TOE, ST, PP, SFR/SAR, EAL) · FIPS 140-3                             |
| 3    | 6–9   | ETSI, GSMA, EMVCo, PCI, MASVS · dersin gereksinim aileleri · uyum matrisi · proje    |

## Kısa tarihçe — güvenlik gereksinimleri nasıl standartlaştı?

- 1985 — TCSEC gereksinim düzeylerini resmîleştirir
- 1994 — FIPS 140 kriptografik modül gereksinimleri (bugün 140-3)
- 1999 — Ortak Kriterler: PP/ST, SFR/SAR, EAL
- 2010'lar — OWASP MASVS (mobil), ETSI EN 303 645 (IoT), EMVCo/PCI (ödeme)

Değişmeyen ilke: gereksinim **ölçülebilir** ve **izlenebilir** olmalı; kanıtsız "karşılandı" geçersizdir.

## Bu hafta nereye oturuyor?

---

- **12. hafta:** bir ürün nasıl **değerlendirilir/test edilir**.
- **Bu hafta (13):** değerlendirmenin ölçtüğü **gereksinimler** nereden gelir, nasıl yazılır, nasıl izlenir.
- Çıktı: projenizin **uyum matrisi** (S17) ve **devredilenler** (S14).

# Öğrenme çıktısı

---

Bu hafta **ÖÇ.7** üstünedir.

Sonunda yapabileceğiniz:

- İyi bir güvenlik gereksinimini kötüsünden ayırmak
- Bir **izlenebilirlik/uyum matrisi** kurmak
- CC, FIPS, ETSI, EMVCo, PCI, MASVS'in ne istediğini karşılaştırmak

# Ana fikir

---

Güvenlik bir "his" değil, **yazılı, ölçülebilir, izlenebilir** gereksinimlerle yönetilir:  
gereksinim → önlem → doğrulama → kanıt.

Bugün bu zinciri kurmayı öğreneceğiz.

# 0. Temel kavramlar (sıfırdan)

# Gereksinim (requirement) nedir?

---

- **Gereksinim:** sistemin **karşılması gereken** bir koşul.
- Güvenlik gereksinimi: bir güvenlik koşulu.
- İyi gereksinim **doğrulanabilir** (test edilebilir).

## Üç tür gereksinim

---

- **İşlevsel:** hangi güvenlik işlevi olacak? (ör. veri AEAD ile korunur)
- **Güvence:** doğru yapıldığına nasıl güveneceğiz? (ör. test raporu)
- **Süreç:** kurum nasıl çalışmalı? (ör. her değişiklik incelenir)

## İyi vs kötü gereksinim

---

- **Kötü:** "Uygulama güvenli olmalıdır." (doğrulanamaz)
- **İyi:** "Sürüm derlemesi yığın koruyucu, PIE ve tam RELRO ile üretilmelidir." (ölçülebilir)

## İzlenebilirlik (traceability)

---

- **İzlenebilirlik:** her gereksinimi bir **önleme**, **teste** ve **kanıta** bağlamak.
- "Bu gereksinim nerede karşılandı, nasıl doğrulandı?"

# Uyum matrisi

---

- **Uyum matrisi:** gereksinim → durum → bölüm → doğrulama → kanıt tablosu.
- Projenin **S17** bölümü.
- Değerlendiricinin ilk baktığı yer.

## Gereksinim durumları

---

- **Karşılandı:** ürün bu gereksinimi sağlar (kanıtla).
- **Devredildi:** başka bir taraf sağlar (kime, neden, nasıl).
- **Karşılanmadı:** henüz sağlanmıyor.

# Devredilen gereksinim

---

- Bir bileşen bir gereksinimi **karşılayamıyorsa**, üst uygulamaya/OS'a **devreder**.
- Kılavuza: **kime**, **neden**, **nasıl** karşılanacağı yazılır.
- Projenin **S14** bölümü.

## Ortak Kriterler (CC)

---

- **Ortak Kriterler (ISO/IEC 15408):** ürün güvenliği değerlendirme standardı.
- Kavramlar: TOE, ST, PP, SFR, SAR, EAL (birazdan).

## CC · temel terimler

---

- **TOE:** değerlendirilen ürün.
- **ST (Security Target):** bu ürünün güvenlik hedefi belgesi.
- **PP (Protection Profile):** bir ürün **sınıfı** için ortak gereksinim seti.

## CC · SFR, SAR, EAL

---

- **SFR:** güvenlik **işlevsel** gereksinimleri.
- **SAR:** güvenlik **güvence** gereksinimleri.
- **EAL:** değerlendirmenin **derinlik** düzeyi (EAL1–EAL7).

## FIPS 140-3

---

- **FIPS 140-3:** kriptografik **modüllerin** doğrulanması standardı.
- Güvenlik düzeyleri (1–4).
- Yalnız modülü kapsar, uygulamanın tamamını değil.

## Sektör standartları

---

- **ETSI EN 303 645:** IoT temel güvenlik.
- **GSMA, EMVCo, PCI:** mobil/ödeme.
- **OWASP MASVS:** mobil uygulama gereksinimleri.

# Şimdi hazırız

---

Terimler:

gereksinim (işlevsel/güvence/süreç) · izlenebilirlik · uyum matrisi · durum  
(karşılandı/devredildi/karşılanmadı) · devredilen · CC (TOE/ST/PP/SFR/SAR/EAL) · FIPS 140-3 ·  
ETSI/GSMA/EMVCo/PCI/MASVS

Şimdi: iyi gereksinim nasıl yazılır?

# 1. İyi gereksinim nasıl yazılır?

# İyi gereksinim ölçütleri — şema

## İyi gereksinimin ölçütleri

bu ölçütleri karşılamayan gereksinim test edilemez

### TEKİL

bir cümle, bir gereksinim

### DOĞRULANABİLİR

nasıl test edileceği bellidir

### İZLENEBİLİR

kaynağı ve kanıtı vardır

### ÖLÇÜLEBİLİR

sayı ya da somut teknik terim içerir

### 'NE' odaklı

'nasıl' yapılacağını dayatmaz

'Uygulama güvenli olmalı' bunların HİÇBİRİNİ karşılamaz.

## Üç tür (hatırlatma)

| Tür      | Soru                   | Örnek                        |
|----------|------------------------|------------------------------|
| İşlevsel | Hangi güvenlik işlevi? | Hassas veri AEAD ile korunur |
| Güvence  | Doğru mu yapıldı?      | Statik analiz + test raporu  |
| Süreç    | Kurum nasıl çalışır?   | Her değişiklik incelenir     |

## İyi gereksinim ölçütleri

---

- **Doğrulanabilir:** test edilebilir mi?
- **Tekil:** tek bir şey mi söylüyor?
- **Ölçülebilir:** somut mu?
- **Gerçekçi:** uygulanabilir mi?

## Kötü → iyi (1)

---

- **Kötü:** "Uygulama güvenli olmalıdır."
- **İyi:** "Sürüm derlemesi yığın koruyucu, PIE ve tam RELRO ile üretilmelidir."

Neden iyi? **Test edilebilir** (checksec).

# Kötü → iyi gereksinim — şema

## Kötü gereksinim → iyi gereksinim

fark: ölçülebilir dayanak ve tekil ifade

### KÖTÜ

'Uygulama güvenli olmalı'  
'Anahtarlar iyi yönetilmeli'  
'Veriler uygun saklanmalı'

→ doğrulanamaz

### İYİ

'C sınıfı her varlık beklemede  
en az 128 bit AES-GCM ile  
şifrelenmelidir'

→ test edilebilir

Zayıf gereksinim test edilemez; test edilemeyen gereksinim karşılandığı kanıtlanamaz.

## Kötü → iyi (2)

---

- **Kötü:** "Veriler şifrelenmelidir."
- **İyi:** "C sınıfı her varlık beklemede  $\geq 128$  bit düzeyinde AEAD ile şifrelenmelidir."

Neden iyi? Hangi veri, hangi düzey, hangi yöntem belli.

## Kötü → iyi (3)

---

- **Kötü:** "Anahtarlar iyi yönetilmelidir."
- **İyi:** "(1) Her anahtarın amacı, kript-periyodu ve imhası belgelenir. (2) İş bitince bellekten silinir."

Tekil, doğrulanabilir maddeler.

## 2. Gereksinimden kanıta: izlenebilirlik

# Zincir

## Gereksinimden kanıta: izlenebilirlik zinciri

her gereksinim bir kanıta bağlanır



Her gereksinim bu zincirle bir **kanıta** bağlanmalı.

## İzlenebilirlik neden önemli?

---

- Değerlendirici "bu gereksinim nerede?" diye sorar.
- İzlenebilirlik yoksa: her şeyi baştan aramak.
- Varsa: matrizen doğrudan bulunur.

## İzlenebilirlik örneği

| Gereksinim       | Önlem     | Doğrulama   | Kanıt          |
|------------------|-----------|-------------|----------------|
| Veri AEAD ile    | AES-GCM   | Birim testi | Test çıktısı   |
| Sürüm korumaları | Bayraklar | checksec    | Koruma tablosu |

## iki yön

---

- **İleri:** gereksinim → nerede karşılandı?
- **Geri:** bu kod/test → hangi gereksinimi karşılıyor?
- İyi matris **iki yönde** de izlenebilir.

## Kanıtsız "karşılandı"

---

- Matriste "karşılandı" ama kanıt yoksa...
- Değerlendirici gözünde **karşılanmamış** sayılır.
- İlk bulgulardan biri olur.

## Bölüm 1–2 — kısa sinama

---

1. İyi gereksinimin dört ölçütü?
2. "Uygulama güvenli olmalı" neden kötü?
3. İzlenebilirlik zinciri nedir?

## Bölüm 1–2 — cevaplar

---

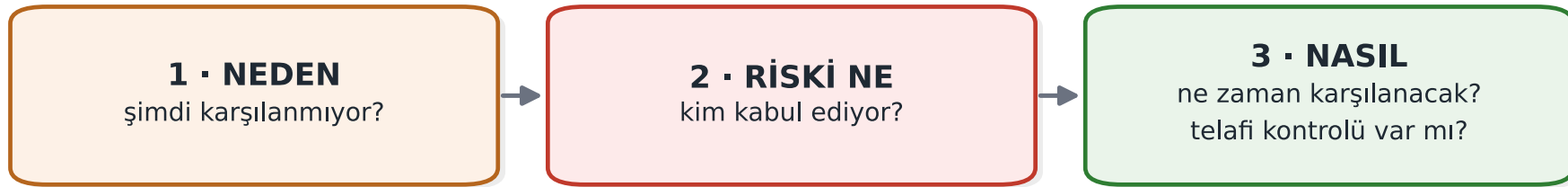
1. **Belirli · ölçülebilir/doğrulanabilir · tekil · izlenebilir** (gerçekçi, atomik).
2. **Belirsiz ve ölçülemez**; "güvenli"nin tanımı yok → test edilemez, herkes farklı anlar.
3. **Tehdit/standart → gereksinim → tasarım/kod → test/kanıt**. Her gereksinim bir kaynağa ve bir kanıta **iki yönlü** bağlanır.

## 3. Gereksinim bloğu ve devredilenler

# Devretme üç soru — şema

## Devrederken yanıtlanacak üç soru

devretmek serbest, SESSİZ devretmek değil



Kayıt ve onay olmadan atlanan gereksinim = gizli açık, sahihsiz risk.

# Gereksinim bloğu kalıbı

---

Her gereksinim bir **blok** olarak yazılır:

- **Kimlik:** benzersiz numara (ör. CEN429-DU-01)
- **Metin:** ne isteniyor (tekil, ölçülebilir)
- **Durum:** karşılandı / devredildi / karşılanmadı
- **Karşılama:** nasıl karşılandı
- **Doğrulama + kanıt**

## Örnek blok

CEN429-DU-01

Metin: Yerel DB'deki C sınıfı veri AEAD ile şifrelenir.

Durum: Karşılandı

Karşılama: AES-256-GCM, anahtar TEE'de

Doğrulama: T-05 birim testi

Kanıt: test çıktısı, S16

## Neden blok?

---

- Her gereksinim aynı yapıda → **karşılaştırılabilir**.
- Değerlendirici hızlı okur.
- Uyum matrisi bu bloklardan üretilir.

## Devredilen gereksinim nedir?

---

- Bir bileşen bir gereksinimi **kendisi** karşılayamıyor.
- Sorumluluğu üst uygulamaya/OS'a/donanıma **devreder**.
- Bu bir kaçış değil, **açık bir sözleşmedir**.

## Devrederken üç soru

---

Devredilen her gereksinimde yaz:

- **Kime?** (üst uygulama / OS / donanım)
- **Neden?** (neden bu bileşen karşılayamıyor)
- **Nasıl?** (karşı taraf nasıl karşılayacak)

## Devredilen · örnek

CEN429-AP-03: Güvenli kurulum ve güncelleme

Durum: Devredildi

Kime: Üst mobil uygulama (MPA)

Neden: SDK dağıtım kanalına sahip değil

Nasıl: MPA imzalı güncelleme + sürüm denetimi sağlar

## Sessiz devretme yok

---

- Bir gereksinimi karşılamıyor ve **yazmıyorsanız** → eksik.
- Devretme **belgelenmeli**; aksi halde "karşılanmadı" sayılır.
- S14 bölümü tam bunun için.

## Karşılandı mı, devredildi mi?

---

| Durum        | Anlamı                                |
|--------------|---------------------------------------|
| Karşılandı   | Ürün sağlar (kanıtla)                 |
| Devredildi   | Başka taraf sağlar (kime/neden/nasıl) |
| Karşılanmadı | Henüz yok (kalan risk)                |

## Bölüm 3 — kısa sinama

---

1. Gereksinim bloğunun alanları?
2. Devrederken hangi üç soru yanıtlanır?
3. Sessiz devretme neden sorun?

## Bölüm 3 — cevaplar

---

1. **ID · ölçülebilir ifade · kaynak/gerekçe · ilgili varlık/tehdit · doğrulama yöntemi (kanıt) · durum/öncelik.**
2. (1) **Neden** şimdi karşılanmıyor? (2) **Riski ne, kim kabul ediyor** (onay)? (3) **Ne zaman/nasıl** karşılanacak (plan/telafi)?
3. Kayıt/onay olmadan gereksinim atlanır → **gizli açık**, sorumlusu yok, denetimde patlar. Açık, gerekçeli, onaylı devret.

## 4. Ortak Kriterler (ISO/IEC 15408)

# Ortak Kriterler — şema

## Ortak Kriterler kavramları

EAL4+ her zaman 'daha güvenli' demek DEĞİLDİR

**PP (Protection Profile)**

ürün SINIFI için standart gereksinim kümesi

**ST (Security Target)**

BELİRLİ ürünün güvenlik hedefi

**SFR**

ürün NE yapacak (fonksiyonel)

**SAR**

buna NE KADAR güvenilecek (güvence)

**EAL**

güvence DERİNLİĞİ — güvenlik miktarı değil

Kapsam (ST/TOE) darsa yüksek EAL az şey kapsar. Kapsamı bilmeden EAL karşılaştırılmaz.

## CC nedir?

---

- **Ortak Kriterler:** ürün güvenliğini değerlendirmenin uluslararası standardı.
- Ortak bir **dil** ve **yöntem** sağlar.
- Ülkeler birbirinin değerlendirmesini tanır.

## TOE · değerlendirme hedefi

---

- **TOE (Target of Evaluation):** değerlendirilen tam ürün.
- Benzersiz tanımlanır (12. hafta): sürüm + ikili + özet.
- Kapsam dışı bileşenler yazılır.

## ST · güvenlik hedefi

---

- **ST (Security Target):** bu ürünün güvenlik hedefi belgesi.
- İçinde: tehditler, amaçlar, gereksinimler (SFR/SAR).
- Ürüne özgüdür.

## PP · koruma profili

---

- **PP (Protection Profile):** bir ürün **sınıfı** için ortak gereksinim seti.
- Örnek: "mobil cihaz PP", "akıllı kart PP".
- ST'ler genelde bir PP'yi temel alır.

## ST vs PP

---

|           | ST               | PP               |
|-----------|------------------|------------------|
| Kapsam    | Tek ürün         | Ürün sınıfı      |
| Kim yazar | Geliştirici      | Topluluk/otorite |
| Rol       | Bu ürünün hedefi | Ortak taban      |

## SFR · işlevsel gereksinimler

---

- **SFR (Security Functional Requirements):** ürünün **ne yapacağı**.
- Örnek: şifreleme, erişim denetimi, günlükleme.
- Standart bir katalogdan seçilir.

## SAR · güvence gereksinimleri

---

- **SAR (Security Assurance Requirements):** doğru yapıldığına **nasıl güveneceğiz.**
- Örnek: kaynak inceleme, test derinliği, zafiyet analizi.
- EAL bunları belirler.

## EAL · değerlendirme derinliği

---

- **EAL (Evaluation Assurance Level):** 1'den 7'ye derinlik.
- Yüksek EAL = daha derin inceleme.
- "+" ek güvence bileşenlerini gösterir (EAL4+).

## EAL yanlış anlaşılması

---

- EAL güvenliğin **derinliği**, güvenliğin **miktarı** değil.
- "EAL4+ > EAL2 daha güvenli" demek **yanlış**.
- Güvenlik, **ST'deki tehdit ve amaçlara** bağlıdır.

## 5. FIPS 140-3

# FIPS 140-3 düzeyleri — şema

## FIPS 140-3 güvence düzeyleri

yukarı çıktıkça fiziksel koruma beklentisi artar



'FIPS doğrulanmış kütüphane kullanıyoruz' demek yetmez: doğru kip ve yapılandırma şart.

## FIPS 140-3 nedir?

---

- **Kriptografik modüllerin** doğrulanması standardı.
- Modülün algoritmaları, kendini testi, anahtar yönetimi.
- Yalnız **modülü** kapsar.

## Güvenlik düzeyleri (1–4)

---

| Düzyey | Kabaca                             |
|--------|------------------------------------|
| 1      | Temel; onaylı algoritmalar         |
| 2      | Kurcalama <b>izi</b>               |
| 3      | Kurcalamaya <b>direnç</b> ve yanıt |
| 4      | En yüksek fiziksel koruma          |

---

## FIPS uyumluluğu tuzağı

---

- FIPS **doğrulanmış** kütüphane kullanmak, uygulamayı otomatik FIPS uyumlu **yapmaz**.
- Uygulama modülü **onaylı kipte** ve **doğru** kullanılmalı.
- Anahtarları da doğru yönetmeli.

## CC ve FIPS birlikte

---

- **CC:** ürünün bütününe değerlendirir.
- **FIPS:** kriptomodülünü doğrular.
- Bir ürün CC değerlendirmesinde FIPS'li modül kullanılabilir.

## Bölüm 4–5 — kısa sinama

---

1. ST ile PP farkı?
2. SFR ve SAR nedir?
3. "EAL4+ her zaman daha güvenli" neden yanlış?
4. FIPS'li kütüphane uygulamayı FIPS uyumlu yapar mı?

## Bölüm 4–5 — cevaplar

---

1. **PP** bir ürün **sınıfı** için standart gereksinim kümesi; **ST** belirli bir **ürünün (TOE)** neyi karşıladığını söyleyen belge.
2. **SFR** ürünün **ne yapacağı** (fonksiyonel); **SAR** buna **ne kadar güvenileceği** (güvence; EAL buradan gelir).
3. EAL **güvence derinliğini** ölçer, güvenlik miktarını değil; **kapsam (ST/TOE)** darsa yüksek EAL az şey kapsar.
4. **Hayır**. Modülü **doğru kip/yapılandırmada, onaylı algoritmalarla** kullanmak gerekir. Modül sertifikası  $\neq$  uygulama uyumu.

## 6. Sektöre özgü gereksinim setleri

# Sektör standartları — şema

## Sektöre özgü gereksinim setleri

hepsi aynı soruyu sorar: hangi gereksinim, hangi kanıtla karşılandı?

**OWASP MASVS / MASTG**

mobil uygulama — bu dersin projesine en yakın

**ETSI EN 303 645**

tüketici IoT

**EMVCo / PCI**

ödeme kartı ekosistemi

**GSMA**

mobil operatör / SIM

Projenizde MASVS seçin: somut, kontrol edilebilir maddeler + MASTG test rehberi.

## Neden sektör standartları?

---

- CC/FIPS geneldir; sektörler kendi risklerine göre **ek** gereksinim ister.
- IoT, mobil, ödeme farklı tehdit ortamları.
- Projeniz hangisine yakınsa onu izleyin.

## ETSI EN 303 645 (IoT)

---

- Tüketici IoT için **temel** güvenlik gereksinimleri.
- Örnek: varsayılan parola yok, güvenli güncelleme, hassas parametreleri güvenli sakla.
- Geniş, uygulanabilir taban.

## ETSI · örnek maddeler

---

- Benzersiz parolalar (ortak varsayılan yok).
- Güvenlik güncellemelerini yönet.
- **Hassas güvenlik parametrelerini güvenli sakla** (→ projede S5/S7/S8).

# GSMA

---

- Mobil operatör ekosistemi için güvenlik yönergeleri.
- Cihaz, ağ, servis güvenliği.
- SIM/eSIM, kimlik.

## EMVCo

---

- Kart ödeme ekosistemi standartları (kartlar, terminaller, mobil ödeme).
- İşlevsel uygunluk + güvenlik değerlendirmesi.
- Saldırı potansiyeli puanlaması (12. hafta).

# PCI

---

- **PCI DSS:** kart verisi işleyen sistemler için güvenlik.
- **PCI MPoC/CPoC:** yazılım tabanlı ödeme kabulü.
- Sıkı; laboratuvar değerlendirmesi.

# OWASP MASVS

---

- **Mobile Application Security Verification Standard.**
- Mobil uygulama güvenlik **gereksinimleri**.
- Düzeyler: temel (L1), derinlemesine (L2), direnç (R).

## MASVS · projeniz için

---

- **En uygulanabilir** gereksinim seti.
- MASTG ile test edilir (12. hafta).
- Kripto, depolama, iletişim, kod kalitesi, direnç.

## Standartlar · karşılaştırma

| Standart     | Alan          | Odak                    |
|--------------|---------------|-------------------------|
| CC           | Genel ürün    | Değerlendirme derinliği |
| FIPS 140-3   | Kripto modülü | Modül doğrulama         |
| ETSI 303 645 | IoT           | Temel gereksinim        |
| EMVCo/PCI    | Ödeme         | İşlevsel + güvenlik     |
| MASVS        | Mobil         | Uygulama gereksinimi    |

## Karşılaştırma · ders

---

- Hepsi aynı kökü paylaşır: **yazılı, doğrulanabilir** gereksinim.
- Fark: kapsam ve sıkılık.
- Projeniz için **MASVS** en pratik başlangıç.

## Bölüm 6 — kısa sinama

---

1. ETSI EN 303 645 kimin için?
2. MASVS neden projeniz için en uygun?
3. CC ile MASVS farkı?

## Bölüm 6 — cevaplar

---

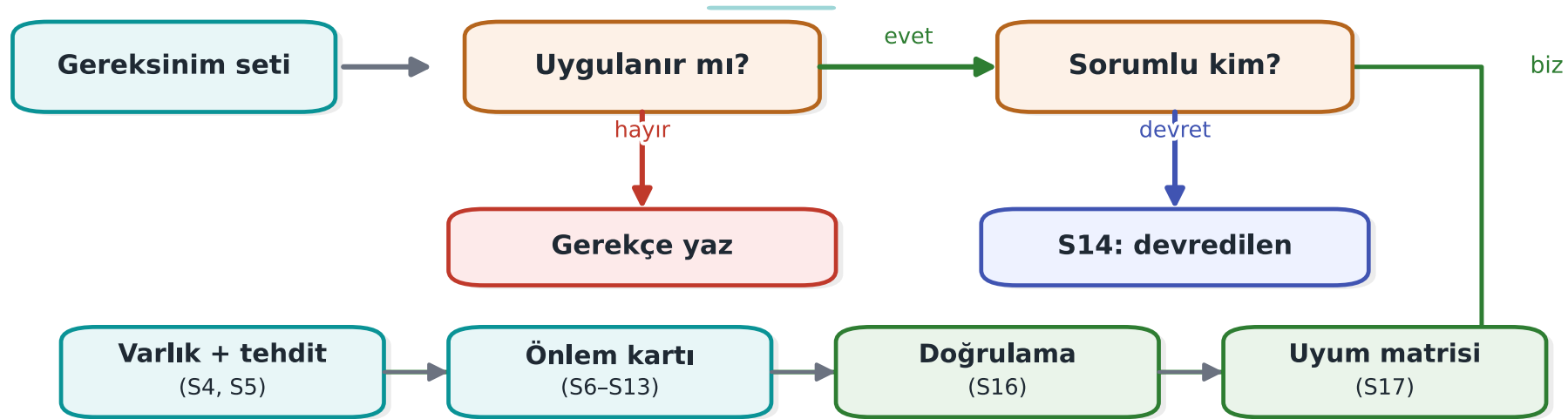
1. Tüketici **IoT** cihazları için temel güvenlik (varsayılan parola yok, güncelleme, güvenli iletişim...).
2. Proje uygulama odaklı; **MASVS** somut, kontrol edilebilir maddeler + **MASTG** test rehberi → doğrudan uygulanır.
3. **CC** ağır, akredite laboratuvar/sertifika (EAL); **MASVS** hafif, açık, geliştirici-dostu **öz-değerlendirme** standardı.

## 7. Gereksinimleri projeye aktarmak

# Gereksinim aktarma kararı — şema

## Gereksinimi projeye aktarma kararı

her gereksinim için aynı soruları sor



Devredilen gereksinim de yazılır: kime, neden, karşı taraf nasıl karşılayacak.

# Gereksinim → varlık → önlem

## Gereksinim bloğunun alanları

her gereksinim bu altı alanla yazılır

|                          |                                        |
|--------------------------|----------------------------------------|
| <b>Kimlik (ID)</b>       | CEN429-DR-01 gibi benzersiz            |
| <b>Ölçülebilir ifade</b> | ne yapılacak                           |
| <b>Kaynak / gerekçe</b>  | hangi tehdit ya da standart            |
| <b>İlgili varlık</b>     | neyi koruyor (S5)                      |
| <b>Doğrulama yöntemi</b> | hangi test kanıtlayacak (S16)          |
| <b>Durum</b>             | karşılandı / devredildi / karşılanmadı |

Alanlardan biri boşsa gereksinim izlenebilir değildir.

Her gereksinim bir **varlığa** ve bir **önleme** bağlanır.

## Varlık yönetimiyle bağ

---

- Gereksinimler S5 **varlık listesine** bağlanır.
- Her varlık: C/I/I+ etiketi, koruma önlemi.
- Gereksinim, o korumayı **zorunlu** kılar.

## Plana aktarmak

---

- İşlevsel gereksinim → tasarım/kod (S6–S11).
- Güvence gereksinimi → test (S16).
- Süreç gereksinimi → geliştirme süreci (S13).

## 8. Dersin gereksinim aileleri

## Dersin kendi kimlikleri

---

Bu ders, açık standartlardan uyarlanmış kendi gereksinim ailelerini kullanır:

CEN429-**AP** (uygulama koruma), **ID** (kimlik), **AS** (varlık), **DR/DU/DT** (veri: beklemede/kullanımda/aktarımda)...

# Aileler (1)

---

| Aile | Konu                            |
|------|---------------------------------|
| AP   | Uygulama koruma (gizleme, RASP) |
| ID   | Kimlik ve bağlama               |
| AS   | Varlık yönetimi                 |
| DR   | Beklemedeki veri                |

---

## Aileler (2)

---

| Aile | Konu              |
|------|-------------------|
| DU   | Kullanımdaki veri |
| DT   | Aktarımdaki veri  |
| RP   | Raporlama/günlük  |
| CR   | Kriptografi       |
| DV   | Geliştirme/süreç  |

---

## Her aile → haftalara bağ

---

- AP → 4, 5, 6, 9, 11, 14
- CR/DR/DU/DT → 3, 10
- AS → 1, 3
- DV/RP → 12, 13

Projeniz bu ailelerden bir **alt küme** seçer.

# Uyum matrisi etkinliği

## Etkinlik · adım 1

---

- Kendi projenizden **beş gereksinim** seçin (farklı ailelerden).
- Her biri için bir **gereksinim bloğu** yazın.

## Etkinlik · adım 2

---

Her gereksinim için matris satırı doldurun:

| Gereksinim | Durum | Bölüm | Doğrulama | Kanıt |
|------------|-------|-------|-----------|-------|
| ...        | ...   | ...   | ...       | ...   |

## Etkinlik · adım 3

---

- En az birini **devredilen** olarak yazın (kime/neden/nasıl).
- En az birinin **kanıtını** somut gösterin.
- Bir "karşılanmadı" varsa **kalan riske** yazın.

# Etkinlik · değerlendirme

---

Değerlendirici gözüyle kontrol:

- Her satırın kanıtı var mı?
- Devredilenler açık mı?
- Gereksinimler **doğrulanabilir** mi?

## Bölüm 7–8 — kısa sinama

---

1. Gereksinim hangi iki şeye bağlanır?
2. Dersin gereksinim ailelerinden üçünü sayın.
3. Uyum matrisinde her satırda ne olmalı?

## Bölüm 7–8 — cevaplar

---

1. Yukarıda **kaynağa** (tehdit/standart/varlık) ve aşağıda **kanıta** (test/kod) — iki yön.
2. (15 aileden herhangi üçü) ör. **veri güvenliği · kod sağlamlaştırma · RASP · kriptografi/sertifika · bellek koruması · arayüz koruması**.
3. Gereksinim **ID+ifade · durum** (karşılandı/devredildi) · **kanıt** (test/dosya/S-bölümü). **Kanıtsız satır karşılanmamış** sayılır.

## 9. Proje ve kapanış

## Proje · S14 ve S17

---

- [ ] **S17 uyum matrisi:** uygulanan her gereksinim için durum, bölüm, doğrulama, kanıt.
- [ ] **S14 devredilenler:** kime, neden, nasıl.
- [ ] En az bir "karşılanmadı" varsa **kalan riske** yaz.

## Değerlendirici gözüyle

---

- Kanıtsız "karşılandı" = karşılanmamış.
- Devredilenler açık ve gerekçeli mi?
- Gereksinimler doğrulanabilir mi?

# Çözümlü kendini sinama

# Soru 1

---

İyi bir güvenlik gereksiniminin dört ölçütü?

**Cevap:** Doğrulanabilir, tekil, ölçülebilir, gerçekçi.

## Soru 2

---

**"Uygulama güvenli olmalıdır" neden kötü? Nasıl düzeltilir?**

**Cevap:** Doğrulanamaz. Ölçülebilir yazılır: ör. "sürüm derlemesi yığın koruyucu, PIE ve tam RELRO ile üretilir".

## Soru 3

---

**İzlenebilirlik zinciri nedir?**

**Cevap:** Gereksinim → önlem → doğrulama → kanıt. Her gereksinim bir kanıta bağlanır.

## Soru 4

---

**Uyum matrisinde kanıtsız "karşılandı" ne demek?**

**Cevap:** Değerlendirici için karşılanmamış sayılır; ilk bulgulardan biridir.

## Soru 5

---

**Bir gereksinimi devrederken hangi üç soru yanıtlanır?**

**Cevap:** Kime, neden, nasıl. Sessiz devretme "karşılanmadı" sayılır.

## Soru 6

---

**ST ile PP farkı?**

**Cevap:** ST tek ürünün güvenlik hedefi; PP bir ürün sınıfı için ortak gereksinim seti. ST genelde bir PP'yi temel alır.

## Soru 7

---

"EAL4+ her zaman EAL2'den güvenli" doğru mu?

**Cevap:** Hayır. EAL değerlendirilmesinin derinliğidir; güvenlik ST'deki tehdit ve amaçlara bağlıdır. "+" ek güvence bileşenidir.

## Soru 8

---

**FIPS doğrulanmış kütüphane kullanan uygulama FIPS uyumlu mudur?**

**Cevap:** Tek başına değil. Doğrulama modülü kapsar; uygulama onaylı kipte, doğru kullanmalı, anahtarları doğru yönetmeli.

## Soru 9

---

**ETSI EN 303 645'in "hassas parametreleri güvenle sakla" maddesi projede nereye karşılık gelir?**

**Cevap:** S5 varlık listesi, S7 veri güvenliği/kabuk matrisi, S8 anahtar yaşam döngüsü.

## Soru 10

---

**Bir kütüphane "güvenli güncelleme" gereksinimini karşılayamıyorsa?**

**Cevap:** Üst uygulamaya devreder ve kılavuzda kime/neden/nasıl karşılanacağını yazar.

## Sözlük

| Terim                  | Anlam                             |
|------------------------|-----------------------------------|
| İşlevsel/güvence/süreç | Üç gereksinim türü                |
| İzlenebilirlik         | Gereksinim→kanıt zinciri          |
| Devredilen             | Başka tarafa aktarılan gereksinim |
| TOE/ST/PP              | CC temel kavramları               |
| SFR/SAR/EAL            | İşlevsel/güvence/derinlik         |

## Özet: bu haftanın tek cümlesi

---

Güvenlik, **yazılı, doğrulanabilir, izlenebilir** gereksinimlerle yönetilir; her gereksinim bir önleme, teste ve **kanıta** bağlanır, karşılanamayan açıkça **devredilir**.

# Gelecek hafta

14. hafta — Tigress ve çeşitlendirme

Gizleme kurallarının otomatik, çeşitlendirilmiş uygulaması; ölçme ve derleme hattı.

# Ek A · İşlenmiş uyum matrisi

## Bağlam · NotKasa

---

Sentetik uygulama: yerel şifreli not tutar, sunucuyla konuşur, güncellenir.

Birkaç gereksinim seçip matris satırı yazalım.

## Gereksinimin doğuşu · tehditten

Tehdit: cihaz çalınırsa yerel notlar okunur



Amaç: beklemede gizlilik



Gereksinim: C sınıfı veri AEAD ile şifrelenir

Gereksinim havadan gelmez; **tehditten** türer.

## Blok · DR-01 (beklemede veri)

CEN429-DR-01

Metin: Yerel DB'deki C sınıfı veri AES-256-GCM ile şifrelenir.

Durum: Karşılandı

Karşılama: AES-256-GCM, anahtar TEE'de

Doğrulama: T-05

Kanıt: test çıktısı (S16)

## Blok · CR-02 (kripto)

CEN429-CR-02

Metin: Anahtarların amacı, kripto-periyodu, imhası belgelenir.

Durum: Karşılandı

Karşılama: S8 anahtar tablosu

Doğrulama: belge incelemesi

Kanıt: S8

## Blok · DT-03 (aktarımda veri)

CEN429-DT-03

Metin: Sunucu iletişimi TLS 1.3 ve sertifika zinciri doğrulaması kullanır.

Durum: Karşılandı

Karşılama: TLS 1.3 + SAN denetimi + SPKI pin

Doğrulama: T-11

Kanıt: test + S11

## Blok · AP-04 (uygulama koruma) — devredilen

CEN429-AP-04

Metin: Güvenli kurulum ve güncelleme sağlanır.

Durum: Devredildi

Kime: Üst uygulama (MPA)

Neden: SDK dağıtım kanalına sahip değil

Nasıl: MPA imzalı güncelleme + sürüm denetimi

## Blok · AS-05 — karşılanmadı

CEN429-AS-05

Metin: Tüm hassas varlıklar için bellek izleme tespiti.

Durum: Karşılanmadı

Kalan risk: köklü cihazda canlı bellek analizi

Azaltma: kısa ömürlü anahtar + sunucu denetimi

## Matris · toplu görünüm

| ID    | Durum        | Bölüm | Kanıt      |
|-------|--------------|-------|------------|
| DR-01 | Karşılandı   | S8    | T-05       |
| CR-02 | Karşılandı   | S8    | S8         |
| DT-03 | Karşılandı   | S11   | T-11       |
| AP-04 | Devredildi   | S14   | —          |
| AS-05 | Karşılanmadı | S12   | kalan risk |

## Matristen okunanlar

---

- Üç karşılandı (kanıtlı), bir devredildi, bir kalan risk.
- Her satır izlenebilir.
- Değerlendirici bu tablodan başlar.

# Ek B · Standart eşleme

# Aynı gereksinim, çok standart

Bir gereksinim birden çok standarda bağlanabilir:

## Uyum matrisi: her satır bir kanıt ister

S17'nin iskeleti

| Kimlik | Gereksinim          | Durum        | Önlem | Kanıt        |
|--------|---------------------|--------------|-------|--------------|
| DR-01  | Beklemede AEAD      | Karşılandı   | S7.2  | test çıktısı |
| AP-07  | Güvenli güncelleme  | Devredildi   | S14.2 | gerekçe      |
| DT-04  | Sertifika sabitleme | Karşılanmadı | —     | kalan risk   |

Kanıt sütunu boş olan 'Karşılandı' satırı, KARŞILANMAMIŞ sayılır.

## Eşleme neden yararlı?

---

- Bir kez karşılırsınız, birçok standardı **aynı anda** sağlarsınız.
- Uyum matrisinde standart sütunu ekleyin.
- Sertifikasyon değişse bile iş tekrarlanmaz.

## Eşleme örneği

| Gereksinim         | ETSI | MASVS   | CC  |
|--------------------|------|---------|-----|
| Şifreli saklama    | ✓    | STORAGE | SFR |
| Güvenli iletişim   | ✓    | NETWORK | SFR |
| Güvenli güncelleme | ✓    | —       | SAR |

## Ek A–B · özet

---

- Gereksinim tehditten türer, blok olarak yazılır, matrise girer.
- Bir gereksinim çok standardı karşılayabilir.
- Kanıt olmadan hiçbir satır "karşılandı" değildir.

# Ek C · Gereksinim aileleri detay

## AP · uygulama koruma

---

- **Örnek:** "Hassas fonksiyonlar gizlenir ve bütünlük denetimiyle korunur."
- Bağ: 4, 6, 9, 11, 14. haftalar.
- Doğrulama: gizleme ölçümü + RASP testi.

## ID · kimlik ve bağlama

---

- **Örnek:** "Cihaz ve sürüm, anahtar kullanımına bağlanır."
- Bağ: 6, 11. haftalar.
- Doğrulama: cihaz bağlama testi.

## AS · varlık yönetimi

---

- **Örnek:** "Her varlık C/I/I+ ile etiketlenir ve yaşam döngüsü belgelenir."
- Bağ: 1, 3. haftalar.
- Doğrulama: S5 varlık listesi.

## DR/DU/DT · veri

---

- **DR (beklemede):** "Yerel veri AEAD ile şifreli."
- **DU (kullanımda):** "Anahtar kullanımdan sonra silinir."
- **DT (aktarımda):** "TLS 1.3 + zincir doğrulama."

## CR · kriptografi

---

- **Örnek:** "Onaylı algoritma, kip ve anahtar uzunluğu; anahtar hiyerarşisi belgeli."
- Bağ: 3, 10. haftalar.
- Doğrulama: algoritma envanteri.

## RP · raporlama

---

- **Örnek:** "Sürümde hassas veri düz loglanmaz."
- Bağ: 4, 6. haftalar.
- Doğrulama: `strings` , günlük denetimi.

## DV · geliştirme/süreç

---

- **Örnek:** "Her değişiklik birleştirilmeden önce incelenir; SBOM güncellenir."
- Bağ: 5, 12, 13. haftalar.
- Doğrulama: süreç kayıtları, SBOM.

## Aileden gereksinime · kural

---

- Projeniz her aileden **en az bir** gereksinim seçer.
- Her gereksinim tehditten türer, blok olarak yazılır.
- Matrise girer, kanıtlarla bağlanır.

# Ek D · Sık yapılan hatalar

## Hata · doğrulanamaz gereksinim

---

- "Güvenli olmalı" gibi ölçülemez ifade.
- Doğrusu: somut, test edilebilir madde.

## Hata · kanıtsız "karşılandı"

---

- Matriste kanıt sütunu boş.
- Değerlendirici karşılanmamış sayar.

## Hata · sessiz devretme

---

- Karşılanamayan gereksinimi yazmamak.
- Doğrusu: kime/neden/nasıl (S14).

## Hata · EAL'i güvenlik miktarı sanmak

---

- "EAL4 > EAL2 daha güvenli" yanlış.
- EAL derinliktir; güvenlik ST'ye bağlı.

## Hata · FIPS'li kütüphane = FIPS uyumlu

---

- Modül doğrulanmış olsa da uygulama doğru kullanmalı.
- Onaylı kip + doğru anahtar yönetimi.

## Hata · kalan riski boş bırakmak

---

- Hiçbir ürünün kalan riski sıfır değildir.
- Boş "kalan risk" = eksik analiz.

## Kontrol listesi

---

- ☐ Her gereksinim doğrulanabilir + tekil
- ☐ Her satırda durum/bölüm/doğrulama/kanıt
- ☐ Devredilenler: kime/neden/nasıl
- ☐ Karşılanmayanlar → kalan risk
- ☐ Standart eşlemesi (ETSI/MASVS/CC)
- ☐ En az bir aile başına gereksinim

## Son söz (13. hafta)

---

Bir gereksinim, tehditten doğar; bir önleme, bir teste ve bir **kanıta** bağlanır; karşılanamıyorsa açıkça **devredilir**. Uyum matrisi bu zincirin haritasıdır.